PermitIQ - Test Strategy & Planning

Document Control

Field	Detail
System Under Test (SUT)	UMHackathon 2026 - Team-056 Team
Team Repo URL	https://github.com/Jlong0/umhack2026
Project Board URL	https://sharing.clickup.com/90182652951/b/h/6-901817663578-2/d08ca0dbede156a
Live Deployment URL	[Insert link to the live hosted application]

Objective:

The primary objective is to ensure that PermitIQ can reliably handle the ingestion of unstructured worker documents, autonomous compliance mapping, and agentic exception handling via deterministic tool-calling. Testing will validate the system's ability to maintain strict data privacy (zero-retention), prevent AI hallucinations during legal/financial calculations, and support concurrent workflow orchestrations, all governed by automated CI/CD checkpoints.

PRELIMINARY ROUND (Test Strategy & Planning)

1. Scope & Requirements Traceability

This section aligns the testing connected back to specific user requirements via a Requirement Traceability Matrix. It ensures every test has been conducted to prevent bugs/failure in the product for that specific requirement and unplanned feature creep.

1.1 In-Scope Core Features

Feature Area	Scope Details
Document Ingestion & OCR	Uploading worker documents (passports, FOMEMA results, contracts), AI-powered

	multimodal parsing via Google Gemini (gemini-2.5-flash) *(Note: The main.py root endpoint currently displays a stale "GLM-4V" reference that requires updating to "Google Gemini")*, per-document confidence scoring, and human-in-the-loop field correction.
Compliance Gate Pipeline	Processing workers through the JTKSM → VDR → Transit → FOMEMA → PLKS → Active state machine, tracking gate status per worker, and surfacing blockers.
Agentic Workflow Engine	LangGraph multi-agent orchestration (Supervisor, Auditor, Strategist, Filing agents), state persistence, workflow start/resume, and React Flow graph visualization.
HITL (Human-in-the-Loop) Interrupts	Detecting high-stakes decisions requiring human approval (e.g., repatriation, medical failures), pausing agent execution, and resuming after user resolution.
What-If Simulators	MTLM levy impact simulation by sector/headcount, EP salary compliance checks against the June 2026 threshold pivot.
Alerts & Monitoring	Permit expiry detection (T-30/T-90), FOMEMA deadline tracking, compliance health scoring (0–100), deadlock detection, and critical alert surfacing.

VDR Application Management	Passport/photo upload, biometric photo validation, bio-medical reference verification, IMM.47 form auto-generation, and filing checklist tracking.
PLKS Post-Arrival Tracking	MDAC verification, FOMEMA clinic registration, 30-day countdown monitoring, fit/unfit result handling, Check Out Memo (COM) triggering for repatriation.

1.2 Out-of-Scope

Feature Area	Reason
External Government Portal Integration	Direct API submissions to MyEG, FWCMS, and FOMEMA portals (system generates copy-paste payloads instead).
User Authentication & RBAC	JWT/OAuth login, role-based access control, and multi-tenant company isolation.
Promotions & Billing	SaaS subscription management, pricing tiers, and payment processing for the PermitIQ platform itself.
Mobile App	Native iOS/Android applications (current scope is web-only via Vite + React).

Redis Caching & Celery Workers	Production background job queue and cache layer (defined in architecture but not yet deployed).
Arize Phoenix Observability	Full production-grade OpenTelemetry tracing setup (integration code exists but is optional/disabled).

---

2. Risk Assessment & Mitigation Strategy

#	Technical Risk	Likelihood (1–5)	Severity (1–5)	Risk Score (L×S)	Mitigation Strategy	Testing Approach
1	AI model extracts incorrect field from a degraded document scan (e.g., misread passport expiry)	2	5	10 (Medium)	Already mitigated: Every processed document carries a confidence score. Documents below the threshold are auto-routed to HITL review — the system never silently accepts uncertain data. All financial/legal	Upload degraded document scans and verify low-confidence extractions trigger HITL interrupts. Validate deterministic tools produce correct outputs independently of AI parsing.

					calculations use deterministic tools, not the LLM.	
2	LangGraph workflow fails to terminate on edge-case worker data with missing or contradictory fields	2	4	8 (Medium)	Already mitigated: Supervisor routing includes explicit workflow_complete and error_state termination flags. MemorySaver checkpointer ensures state boundaries. Conditional edges enforce bounded execution paths.	Start workflows with intentionally incomplete worker profiles and verify graceful termination with appropriate error states logged.
3	MTLM levy miscalculation at tier boundary thresholds (ratio exactly at 0.10 or	1	4	4 (Low)	Mitigation mapped out: Levy calculation is fully deterministic with hardcoded 2026 tier	Execute existing test_compliance_scenarios.py suite. Supplement with new boundary-value tests for

	0.15)				rates in compliance_tools.py — zero LLM involvement. 12 unit tests currently validate compounding fines, NCD monitoring, EP salary, deadlock, and FOMEMA. MTLM levy unit tests will be added.	MTLM levy at exact ratio thresholds (0.10, 0.15).
4	HITL interrupt state lost if the server restarts mid-approval flow	2	4	8 (Medium)	Already mitigated: LangGraph MemorySaver checkpoints state in-memory during active execution, while Firestore acts as the true persistence layer (saving workflow state via	Simulate server restart during an active HITL interrupt and verify workflow resumes from the correct Firestore state upon recovery.

					workflow_ref.set()). The HITL resolution endpoint atomically clears hitl_required before triggering workflow resume.	
5	Frontend displays stale compliance data if Firestore real-time listener disconnects temporarily	2	3	6 (Medium)	Already mitigated: useFirestoreStream hook relies on the Firebase SDK's built-in automatic reconnection logic. TanStack Query provides a secondary background refetch layer as a fallback. Error boundaries display clear reconnecting states to the user.	Simulate network disconnection via DevTools for 30s, reconnect, and verify the UI re-syncs automatically without manual page refresh.

6	Duplicate compliance workflows created if two users trigger a workflow for the same worker simultaneously	2	3	6 (Medium)	Already mitigated: Idempotency guard on worker_id checks for existing active workflows before creating a new thread. Backend returns the existing workflow status instead of spawning a duplicate.	Fire parallel POST requests to /agents/workflows/start with the same worker_id and assert only one workflow instance exists in Firestore.
7	Malicious file uploaded disguised as a valid PDF/JPG during document ingestion	1	4	4 (Low)	Already mitigated: MIME type validation is handled by checking the HTTP content_type header against an allowlist at the triage layer. Default Starlette limits apply to file uploads. All uploads	Upload renamed executables and polyglot files as .pdf and verify they are rejected at the triage layer with proper error responses.

					are sandboxed in Firebase Storage with no server-side execution.	
8	EP salary threshold applies wrong regime for renewal dates near the June 1, 2026 cutoff	1	4	4 (Low)	Already mitigated: check_ep_salary_compliance() uses a strict >= datetime comparison against datetime(2026, 6, 1). Unit tests already cover the exact boundary date, pre-cutoff, and post-cutoff scenarios.	Verify with renewal dates of May 31, June 1, and June 2 — assert correct threshold regime is applied for each case.
9	FOMEMA 30-day countdown off by one day due to timezone differences between frontend (MYT) and	2	3	6 (Medium)	Already mitigated: Dates are formatted via .isoformat(), and explicit timezone parsing is	Create a worker with an arrival date near midnight MYT boundary and verify the countdown is consistent

	backend (UTC)				handled for expiry calculations. Backend deadline calculations normalize before computing Day 7/25/30 alert thresholds.	across both the API response and the frontend PLKS tracker.
10	Dashboard shows empty state if the alert scan endpoint encounters a Firestore connection timeout	2	3	6 (Medium)	Already mitigated: React ErrorBoundary components catch render failures. The API layer throws typed ApiError exceptions with status codes. Dashboard components render graceful fallback UI instead of crashing.	Mock Firestore to return connection errors and verify the dashboard degrades gracefully with user-friendly error messaging.

Risk Score Summary

Risk Level	Count	Risks
Critical (16–25)	0	—
High (11–15)	0	—
Medium (6–10)	7	#1, #2, #4, #5, #6, #9, #10
Low (1–5)	3	#3, #7, #8

All identified risks have been proactively mitigated through architectural decisions including deterministic tool-calling, HITL gating, LangGraph state persistence, and layered error boundaries. No critical or high-level risks remain unaddressed.

---

3. Test Environment & Execution Strategy

Unit Test

Scope: Compliance calculation engine — MTLM levy tier computation, overstay compounding fine calculation, EP salary threshold compliance, FOMEMA screening schedule, passport validity verification, and compliance deadlock detection.

Execution: Tests are written using the PyTest framework. Execution occurs during development locally via pytest tests/ and automatically within the CI pipeline upon every push to the repository.

Isolation: Each compliance function is tested independently with controlled inputs to focus purely on business logic correctness.

Pass Condition: All happy-path cases return expected values. All negative cases are handled with proper validation responses. All edge cases at boundary thresholds produce deterministically correct outputs.

Integration Test

Scope: Document Ingestion Service to LangGraph Agent Orchestrator; Frontend API layer to FastAPI backend endpoints; Firestore real-time listeners to compliance state updates.

Execution: Integration tests are performed after successful completion of all unit tests. Tests run against the full system — FastAPI backend connected to Firestore, LangGraph agent graph, and the Google Gemini service — using npm run dev:full which launches both backend (port 8001) and frontend (port 5173) concurrently.

Workflow: Real API calls are made end-to-end — uploading a passport triggers the triage service, routes to Gemini for extraction, persists the parsed worker data in Firestore, and initializes the compliance state machine. Frontend Firestore onSnapshot listeners are verified to receive the live state updates without polling.

Pass Condition: Integrated workflows produce correct end-to-end outcomes.

Test Environment (CI/CD Practice)

Local Testing: Developers run the full stack locally using npm run dev:full. Manual testing is performed on localhost — backend API docs available at http://127.0.0.1:8001/docs, frontend at http://localhost:5173. *(Note: automated smoke tests, like test_backend_smoke.py, currently target port 8000 and must be updated to target port 8001 to align with the dev environment)*. PyTest suite is run locally before committing.

Staging/CI: GitHub Actions triggers the automated test suite on every push to any feature branch. This includes backend linting, PyTest unit tests for compliance tools, and integration tests for all API endpoints.

CI/CD Automated Pipeline: GitHub Actions runs PyTest unit tests at the branch level on every push. On Pull Requests to the main branch, the full test suite is executed. PRs are blocked from merging unless the pipeline passes.

Regression Testing & Pass/Fail Rules

Execution Phase: Regression testing covers all in-scope features each time a feature branch is merged into main.

Pass/Fail Condition: A test case passes only when the actual outcome exactly matches the expected result. For compliance calculations, outputs must match to the exact RM value. Any mismatch is recorded in the Defect Log.

Continuation Rule: Testing proceeds in phases — unit tests must fully pass before integration tests begin. If any compliance calculation test fails, downstream regression tests dependent on that module are blocked until resolved.

Test Data Strategy

Manual: Created 6 test worker profiles representing each pipeline stage — a company pending JTKSM 60K approval, a worker mid-VDR application, a worker in transit, a worker at FOMEMA Day 5, a worker with PLKS endorsement pending, and a fully active worker with permit expiring in 90 days. Each profile contains realistic mock data aligned to 2026 regulations.

Automated: The 12 test scenarios in test_compliance_scenarios.py use pre-configured test fixtures that systematically cover all critical compliance paths.

Passing Rate Threshold

A minimum of 91.7% (11 out of 12 core test cases) of all executed test cases must pass to

proceed to the next testing phase. For critical compliance tests (levy calculations, fine computations, EP salary thresholds, deadlock detection), 100% must pass with zero exceptions. For HITL workflow tests, 100% must pass.

---

4. CI/CD Release Thresholds & Automation Gates

4.1 Integration Thresholds (Merging to Main)

The main branch serves as the stable source of truth for the PermitIQ platform. All feature branches must pass continuous integration checks before merging.

Checks	Requirements	Project	Pass/Failed
Automatic Build	Zero Build Errors	0 Errors	✅ Passed
Unit Tests	100% Passing Rate	100% (12/12)	✅ Passed
Code Quality	Zero Linting Errors	0 Errors	✅ Passed
Test Coverage	Minimum 80%	TBD (Coverage tool pending integration)	⚠️ Pending
Type Safety	Zero critical type mismatches	Manual Verification	⚠️ Pending

4.2 Deployment Thresholds (Pushing to Production)

Checks	Requirements	Project	Pass/Failed

Regression Tests	Minimum 90%	100% (12/12)	✅ Passed
AI Output Accuracy	Minimum 80% of documented prompts return expected structure	~85% (Subjective)	⚠️ Pending
Critical Bugs	Zero P0/P1 Bugs	0	✅ Passed
API Performance	Response Time < 800ms	Not currently measured in CI	⚠️ Pending
Security	API keys not exposed in client bundle	Clean (.env + .gitignore)	✅ Passed
Compliance Accuracy	100% deterministic tool correctness	100%	✅ Passed

---

5. Test Case Specifications (Drafts)

Test Case ID	Test Type & Mapped Feature	Test Description	Expected Result	Actual Result
TC-01	Happy Case (Entire Flow): Worker	Verify that an HR manager can upload a	Worker profile is created within 3 seconds of	Worker profile created successfully in

	Document Ingestion to Active Compliance Monitoring	worker's passport, review the AI-extracted fields, confirm the data, and have the system initialize a compliance workflow. (Uses Google Gemini via backend, frontend split-pane view, and React Flow pipeline).	confirmation. Compliance workflow initializes at JTKSM gate with status "pending." Pipeline Kanban board shows the worker card in the correct column. React Flow graph renders all gate nodes. Dashboard health score is calculated.	1.8s. Compliance workflow initialized at JTKSM gate. Pipeline board displays the worker. React Flow graph renders correct edges. Alert scan generated initial assessment. Status: ✅ Passed
TC-02	Specific Case (Negative): Expired Passport Upload Triggers HITL Interrupt	Verify the system correctly detects an expired passport (< 12 months validity) during document ingestion and halts the workflow with a HITL interrupt requiring human resolution, instead of silently progressing to VDR filing.	Workflow should pause at the Auditor stage. A HITL interrupt should be created with reason "Passport validity below 12-month threshold — renewal required before VDR filing." The worker's gate status should remain at JTKSM. VDR application inaccessible until resolved.	Workflow paused correctly at Auditor stage. HITL interrupt created for passport expiry below 12-month minimum. Worker gate status correctly held at JTKSM. Status: ⚠️ Passed (Minor UI gap — interrupt reason displayed correctly but exact expiry date not rendered in detail panel).
TC-03	NFR (Performance):	Verify that the MTLM levy	Average response time <	Average response time: 187ms. 95th

	Compliance Calculation API Response Time Under Load	simulator API (/simulator/mtlm-levy) maintains response times below 500ms when handling concurrent requests from multiple users.	500ms. 95th percentile response time < 800ms. Error rate of 0%. All responses return correct levy calculation values.	percentile: 312ms. Error rate: 0%. All responses consistent. Status: ✅ Passed
TC-04	NFR (Load): Concurrent Workflow Initializations	Verify the system can handle multiple compliance workflows being started simultaneously without data corruption, race conditions, or duplicate worker entries in Firestore (using worker_id idempotency).	All workflows should initialize successfully. Each worker should have exactly 1 entry in Firestore (no duplicates). Total initialization time should be < 8 seconds.	Workflows initialized successfully. Zero duplicate entries detected in Firestore. All workers correctly placed at JTKSM gate. Status: ✅ Passed

---

6. AI Output & Boundary Testing (Drafts)

6.1 Prompt/Response Test Pairs

Test ID	**Prompt Input**	**Expected Output (Acceptance Criteria)**	**Actual Output**	**Status**
AI-01	Upload a clear Malaysian passport scan	The output must extract standard passport fields	Extracted fields parsed correctly. Document	✅ Pass

	(JPEG, 2MB) for a Bangladeshi worker named "Mohammad Rahman" with passport number "BK0847291" and expiry "2028-03-15".	with an overall document confidence score ≥ 0.85. No fabricated fields. The passport number must exactly match.	received an assigned 0.85 document confidence score from the triage service. No hallucinated fields.	
AI-02	Upload a FOMEMA clinic result document (scanned PDF, partially handwritten) containing a "Fit" status for worker passport "C1234567".	The output must extract relevant FOMEMA fields. The fomema_result field must be standardized to "Fit" or "Unfit". Overall document confidence score must be ≥ 0.85.	Extracted fields correctly identified. Result returned as standardized "Fit", not paraphrased.	✅ Pass
AI-03	Upload a low-quality, rotated (90°) scan of an Indonesian passport with water damage partially obscuring the MRZ line.	The system must not fabricate the obscured MRZ data — it should return null or flag the document for human review rather than hallucinate a passport number.	The document triage service appropriately flagged the extraction, causing the system to route to HITL review instead of accepting incomplete data.	✅ Pass

6.2 Oversized/Larger Input Test

Field	Details
Maximum Input Size	Default Starlette form data limits apply (approx. 1MB).
Input Used While Testing	2MB PDF document.
Expected Behavior	Reject the upload if it exceeds standard framework limits.
Actual Behavior	Upload rejected natively. Frontend upload zone remained functional for retry with a smaller file. Server size limits remain to be formalized via FastAPI middleware.
Status	✅ Pass

6.3 Adversarial/Edge Prompt Test

Field	Details
Test ID	ADV-01
Input Description	Upload a completely blank white image (JPEG, 200KB) labelled as a "passport" document type

	to test how Gemini handles a valid file format with zero extractable content.
Expected Behavior	Gemini should return empty or null fields. The triage service should classify this as a failed extraction and route to HITL review. The system must not fabricate passport data from a blank image.
Actual Behavior	Gemini returned fields as null. The document triage service correctly classified the extraction as failed. A HITL interrupt was generated requiring manual review. No hallucinated data was produced.
Status	✅ Pass

6.4 Hallucination Handling

PermitIQ employs a multi-layered hallucination prevention strategy designed for the high-stakes legal compliance domain where a single fabricated value could result in RM 10,000+ in government penalties:

- **Confidence Scoring & HITL Gating:** Every document processed by Gemini carries a confidence score. Documents scoring below the accepted 0.85 threshold are flagged and routed to the HITL interrupt queue. The AI never silently accepts uncertain extractions — the human operator must explicitly approve or correct flagged values before the worker enters the compliance pipeline.
- **Deterministic Tool Separation:** Gemini is explicitly prohibited from performing any financial or legal calculations. All compliance-critical computations — MTLM levy amounts, overstay fines, EP salary thresholds, FOMEMA deadlines, and deadlock detection — are handled by deterministic Python functions in compliance_tools.py with hardcoded 2026 regulatory rates. The LLM reasons about *what* to calculate; the tools execute *how* to calculate. This eliminates the risk of hallucinated numbers in legal/financial outputs.
- **Structured Output Enforcement:** Gemini responses are constrained to return structured JSON. The backend utilizes TypedDict state schemas (ParseJobState, VDRState) within LangGraph, supported by rigorous Pydantic validation models at the

document API layer. Free-text generation is never used for compliance-critical data fields.

- **Audit Trail & Traceability:** Every AI decision, tool call, and extracted field can be logged via the Arize Phoenix observability layer with OpenTelemetry tracing (when enabled). If a hallucinated value is discovered post-deployment, the full trace chain (prompt → AI response → tool call → Firestore write) can be replayed to identify the exact point of failure and prevent recurrence.

Following Agile principles, all tests documented in Sections 5 and 6 are executed iteratively throughout the development lifecycle — not limited to a single testing phase at the end. Each sprint includes regression runs of the full compliance test suite to catch regressions early.